

Capitolo 5 -Autenticazione Utenti

Fondamenti: Identificazione vs Autenticazione

La base della sicurezza informatica risiede nel **controllo degli accessi**. Questo concetto implica che un soggetto sia autorizzato a compiere una determinata azione su una risorsa. Per far sì che ciò funzioni, dobbiamo essere certi dell'identità di quel "qualcuno". Il processo di determinazione dell'identità si suddivide in due fasi distinte:

- **Identificazione:** l'atto di asserire chi sia un soggetto. L'utente si identifica presso il sistema presentando una credenziale, come l'ID utente.
- **Autenticazione:** l'atto di provare che l'identità dichiarata sia corretta, ovvero che il soggetto sia effettivamente chi afferma di essere. Il sistema verifica l'utente attraverso lo scambio di informazioni di autenticazione.

Mentre le identità sono spesso note, prevedibili o facilmente intuibili, le informazioni di autenticazione dovrebbero rimanere private. Se il processo di autenticazione non è sufficientemente robusto, l'intero sistema non può essere considerato sicuro. I meccanismi si basano su tre pilastri: qualcosa che l'utente **sa** (conoscenza), qualcosa che l'utente **è** (biometria/caratteristiche) o qualcosa che l'utente **ha** (token/possesso).

Autenticazione basata sulla Conoscenza: Le Password

L'autenticazione basata su frasi e fatti è il meccanismo più diffuso, ma presenta notevoli difficoltà d'uso e gestione:

- **Incombenza:** fornire una password per ogni accesso a un oggetto può risultare scomodo e dispendioso in termini di tempo.
- **Divulgazione:** se la password viene rivelata a un individuo non autorizzato, l'oggetto protetto diventa immediatamente accessibile. Per *ri-proteggerlo*, l'utente deve cambiare la password e informare tutti gli altri utenti legittimi.
- **Revoca:** revocare il diritto di accesso a un singolo utente richiede il cambio della password per tutti, causando gli stessi disagi della divulgazione.
- **Perdita:** può essere impossibile recuperare una password dimenticata, a meno che l'amministratore di sistema non ne fornisca una nuova.

Gli Step di Attacco alle Password

Un attaccante può seguire una progressione di 12 step per tentare di indovinare una password:

1. Nessuna password.
2. Password uguale allo User ID.

3. Derivata dal nome o dall'ID dell'utente.
4. Parole comuni (es. "password", "secret") o pattern di tastiera (es. "qwerty", "aaaaaa").
5. Termini contenuti in un dizionario tascabile.
6. Termini di un dizionario inglese completo.
7. Termini di dizionari in altre lingue.
8. Termini di dizionari con variazioni di maiuscole o sostituzioni di caratteri (es. '0' per 'O', '1' per 'l').
9. Brute force su tutte le combinazioni alfabetiche.
10. Brute force sull'intero set di caratteri.

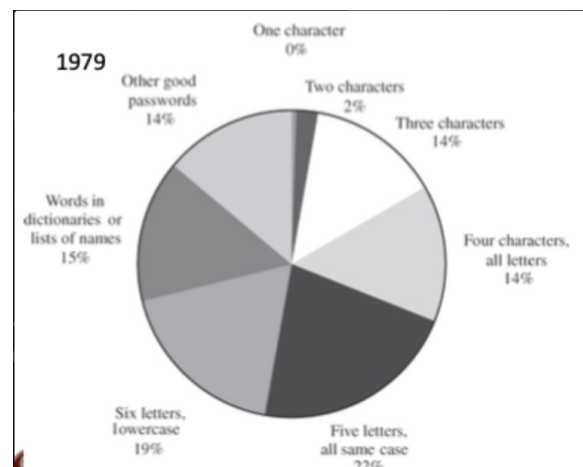
Sebbene questi step richiedano tempo, per un attaccante il tempo non è un fattore limitante. La forza di una password non risiede nella sua segretezza assoluta, ma nel numero di tentativi richiesti per indovinarla.

Debolezza del Fattore Umano

Le password sono un mezzo economico ed efficiente, ma il loro punto debole è l'essere umano che le sceglie. Gli utenti tendono a usare pattern prevedibili o mostrano negligenza.

Le abitudini umane nella scelta delle password non siano cambiate dal 1979 a oggi.

- **Dati storici (1979):** Uno studio di Morris e Thompson mostrava già una forte prevalenza di password brevi (3-6 caratteri) o basate su parole del dizionario.
- **Dati recenti (2019 - Dataset di 500M di password):**
 - Circa il **30%** degli utenti sceglie password con meno di sette caratteri.
 - Quasi il **50%** utilizza nomi, parole gergali, termini del dizionario o pattern banali (cifre consecutive, tasti adiacenti sulla tastiera).
 - Tra le password più popolari figurano ancora "123456", "password" e "iloveyou".



Le strategie degli attaccanti

Gli attaccanti sfruttano le caratteristiche psicologiche degli utenti a proprio vantaggio poiché gli utenti solitamente evitano password lunghe, non comuni o difficili da compitare/pronunciare. Inoltre l'attaccante cercherà di ridurre lo "spazio di ricerca". Se le persone preferiscono password brevi, l'attaccante le proverà in ordine di lunghezza.

Gli attaccanti sfruttano queste debolezze tramite:

- **Dictionary Attack:** utilizzo di liste specializzate che includono nomi di fantascienza, luoghi, termini mitologici e parole in varie lingue.

- **Inferenza:** gli utenti preferiscono password brevi, facili da scrivere e da pronunciare. Un attaccante riduce lo spazio di ricerca provando le password in ordine di lunghezza. Per Esempio:

esistono solo $26^1 + 26^2 + 26^3$ combinazioni alfabetiche di lunghezza ≥ 3

- **Rainbow Tables:** I sistemi operativi non salvano le password in chiaro, ma in forma "oscurata" (tramite cifratura o hashing). Se un attaccante ottiene la tabella delle password oscurate, può violarla senza interagire con il sistema:

Plaintext		Concealed (encryption or hashing)	
Identity	Password	Identity	Password
Jane	qwerty	Jane	0x471aa2d2
Pat	aaaaaa	Pat	0x13b9c32f
Phillip	oct31witch	Phillip	0x01c142be
Roz	aaaaaa	Roz	0x13b9c32f
Herman	guessme	Herman	0x5202aae2
Claire	aq3wm\$oto!4	Claire	0x488b8c27

- Costruisce una **RAINBOW TABLE**: una tabella pre-calcolata che contiene coppie di "password in chiaro" (tratte da dizionari) e i relativi "valori oscurati".
- Confronta i valori oscurati rubati con quelli nella Rainbow Table.
- Quando trova una corrispondenza, ottiene istantaneamente la password in chiaro.

Rainbow Table	Original Password	Encrypted Password
	asdfg	0x023c94fc
	p@55w0rd	0x04ff38d9
	aaaaaa	0x13b9c32f
	password	0x2129f30d
	qwerty	0x471aa2d2
	12345678	0x4f2c4dd8
	123456	0x5903c34d
	aaaaa	0x8384a8c8

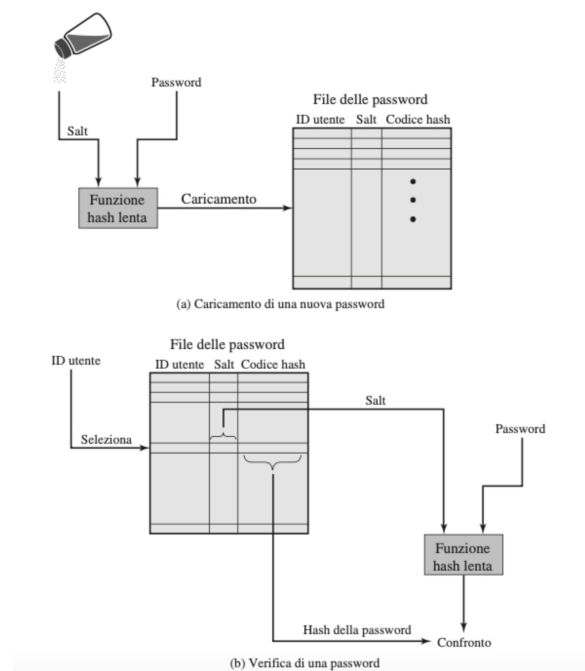


- **Brute Force:** l'attaccante prova tutte le combinazioni di password possibili.

La contromisura per il Rainbow: SALT

Il problema principale dell'oscuramento semplice è che password uguali generano valori oscurati identici. Per contrastare le Rainbow Table, si introduce il **Salt**:

- È un campo dati extra unico per ogni utente (es. data di creazione account, parte del nome o valore casuale).
- Viene unito alla password prima del processo di hash.



I vantaggi sono molteplici: impedisce che password uguali siano visibili come tali, rende impossibile sapere se un utente usa la stessa password su più sistemi e aumenta la difficoltà degli attacchi offline di un fattore 2^b , dove b è il numero di bit del salt.

Autenticazione Biometrica

La biometria utilizza caratteristiche fisiche o comportamentali: impronte digitali, geometria della mano, retina, iride, voce, firma, dinamica di digitazione o vasi sanguigni.

- **Vantaggi:** non può essere persa, rubata o dimenticata; è sempre disponibile ed è difficile (ma non impossibile) da falsificare.
- **Funzionamento:** richiede la registrazione di un "template" (modello) delle caratteristiche del soggetto. Durante l'autenticazione, le nuove misurazioni vengono confrontate con il template.

Test Dicotomici e Prestazioni

L'autenticazione ha successo se il match è "abbastanza vicino" (es. 90% di corrispondenza o parametri entro il 5% di tolleranza). Questo è un **test dicotomico**: o c'è un match, o non c'è. I risultati possibili sono:

- **True Positive (tp):** Corretto riconoscimento dell'utente legittimo.
- **False Positive (fp):** Errore critico per la sicurezza; un impostore viene accettato.
- **False Negative (fn):** Errore critico per l'usabilità; l'utente legittimo viene rifiutato.
- **True Negative (tn):** Corretto rifiuto di un impostore.

Le metriche di valutazione includono:

Sensibilità: Misura la proporzione di risultati positivi tra tutti i possibili match corretti (la capacità di identificare correttamente il soggetto cercato).

$$\frac{tp}{tp + fn}$$

Specificità: Misura la proporzione di risultati negativi tra tutte le persone che non sono il soggetto cercato (la capacità di escludere correttamente gli impostori).

$$\frac{tn}{fp + tn}$$

Accuratezza: Misura il grado in cui il test segnala correttamente la condizione o situazione complessiva.

$$\frac{tp + tn}{tp + tn + fp + fn}$$

Prevalenza: Indica quanto è comune una determinata condizione o situazione all'interno della popolazione del test.

$$\frac{tp + fn}{tp + tn + fp + fn}$$

Sensibilità e specificità sono legate statisticamente: se una aumenta, l'altra diminuisce. Ridurre i falsi positivi aumenterà inevitabilmente i falsi negativi. Il compromesso è rappresentato dalla curva **ROC (Receiver Operating Characteristic)**.

Limiti della Biometria

La biometria può essere intrusiva e rappresenta un "single point of failure". L'accuratezza è limitata dalla velocità di riconoscimento necessaria e dalla possibilità di falsificazioni. Inoltre, è un meccanismo **debole per l'identificazione** (cercare un match tra tutti i template) a meno che ogni template non sia unico, ma **forte per l'autenticazione** (confronto con un template specifico).

Token e Identità Federata

I token si dividono in:

- **Passivi:** il contenuto non cambia (es. chiavi fisiche, foto).

- **Attivi:** possono variare o interagire con l'ambiente (es. smart card, RFID).
- **Dinamici:** generano valori imprevedibili (pass-number) che cambiano nel tempo o su richiesta, eliminando la vulnerabilità allo **skimming** (copia furtiva dei dati tramite dispositivi appositi).

FIM e SSO

- **Federated Identity Management (FIM):** unione di sistemi di identificazione separati che condividono un unico profilo e database di identità autenticate.
- **Single Sign-On (SSO):** procedura "ombrello" che gestisce identità e codici per diversi processi, permettendo all'utente di loggarsi una sola volta per sessione.
- **Multi-factor Authentication (MFA):** combinazione di più approcci (es. password + token dinamico). Sebbene più sicura, aumenta la complessità e può frustrare l'utente se il numero di fattori n è troppo elevato.

Riepilogo dei Rischi di Sicurezza

Attacco	Bersaglio e Caratteristiche
Denial of Service	Inonda il servizio di autenticazione per disabilitarlo. Può mirare a bloccare utenti specifici tramite i meccanismi di logout.
Eavesdropping	Tentativo di apprendere la password tramite vicinanza fisica (shoulder surfing) o keylogging.
Host Attack	Diretto al file dei server dove sono memorizzati password, codici token o template biometrici.
Trojan Horse	Un'applicazione o un dispositivo fisico che si maschera da autentico per catturare le credenziali.
Client Attack	L'attaccante cerca di autenticarsi senza accedere al server o al canale di comunicazione, mascherandosi da utente legittimo.
Replay Attack	Ripetizione di una risposta di autenticazione precedentemente catturata.